Securing AI in Healthcare

Protecting patient data while still shipping innovation

Slide 1

The story we're living

- Patients expect Amazon-level experiences in care
- AI is powering search, personalization, and support
- Security mistakes break trust fast — and spread faster
- Goal today: ship AI safely without slowing teams

Slide 2

Agenda

- AI security risks unique to healthcare
- What HIPAA/GDPR mean in practice
- Real incidents and lessons learned
- A practical control stack (data → model → app)
- 30/60/90-day rollout plan + checklist

Why healthcare + marketing teams care

- Trust is a growth metric (conversion, retention, referrals)
- Bad personalization can expose sensitive signals
- Outages impact care journeys and call centers
- Compliance is evidence-driven — not intent-driven

Healthcare is different

- Health data is identity + vulnerability (can’t “reset” it)
- Availability is safety (downtime can delay care)
- Ecosystem complexity: vendors + portals + claims + devices
- Regulators expect risk analysis and proof of controls

AI isn’t one thing

DATA
Data layer: collection, storage, sharing, labeling

MODEL
Model layer: training, evaluation, versioning

APP
App layer: APIs, websites, chat, workflows

OPS
Ops layer: monitoring, incident response, governance

What attackers want

- Steal PHI/PII (fraud, extortion, resale)
- Disrupt operations (ransomware pressure)
- Manipulate outcomes (recommendations, triage)
- Abuse compute / steal IP (models and pipelines)

AI-specific risks (simple list)

- Training data leakage (membership inference / inversion)
- Data poisoning (small bad data → big behavior shift)
- Adversarial inputs (tiny changes → wrong output)
- Prompt injection in GenAI apps (tool hijack / exfiltration)

Incident: WannaCry (NHS)

- Disrupted services and cancelled appointments
- Basic hygiene gaps: patching + asset visibility
- Lesson: availability is a patient-safety control

Incident: Anthem

- Large breach of sensitive member data
- Lesson: risk analysis + monitoring + access controls
- Evidence matters: logs, policies, and enforcement readiness

Incident: Change Healthcare

- Ecosystem disruption hit claims + pharmacy workflows
- Lesson: identity controls (MFA) are non-negotiable
- Vendor risk is not “someone else’s problem”

Privacy lesson: when consent is missing

- Innovation fails when transparency fails
- Patients must understand how data is used
- Lesson: privacy-by-design is a launch requirement

Where PHI leaks in digital journeys

- Analytics tags/pixels on authenticated pages
- Search terms, form fields, and URL parameters in logs
- Chat transcripts and session replay tools
- Dashboards or storage misconfigurations

3 questions before we ship AI

1. What data touches the model?
2. What can the model output?
3. What actions can the app take with that output?

NIST AI RMF (easy translation)

GOVERN
assign owners, policies, risk tolerance

MAP
document context + data flows + intended use

MEASURE
test privacy, security, robustness

MANAGE
monitor, respond, continuously improve

HIPAA Security Rule — plain English

- Protect ePHI with admin + physical + technical safeguards
- CIA triad: confidentiality, integrity, availability
- Risk analysis → risk management → ongoing monitoring
- Keep audit-ready evidence (policies + logs + training)

GDPR Article 32 — plain English

- Security measures appropriate to risk
- Encryption/pseudonymization when relevant
- Resilience + restore access quickly
- Regular testing of controls

Data protection controls (must-haves)

- Minimize data: collect only what you need
- De-identify early; separate identifiers from behavior data
- Encrypt in transit/at rest; rotate keys; segregate duties
- Least privilege + MFA + break-glass procedures

Model security controls (often missed)

- Secure training pipeline (provenance + approvals)
- Leakage tests + red teaming for sensitive use cases
- Robustness testing where impact is high
- Model registry + versioning + rollback plan

GenAI apps (chatbots / RAG) controls

- Treat prompts like untrusted input
- Guardrails: output filtering + PHI redaction
- Tool isolation: allowlists + least privilege connectors
- Safe logging: avoid storing prompts/responses with PHI

Operational readiness

- Tabletop exercises focused on patient impact
- Ransomware playbook: isolate → restore → communicate
- Vendor response: SLAs + evidence expectations
- Monitoring: anomaly alerts for AI APIs and data access

Marketing personalization patterns that are safe

- Separate public content vs authenticated PHI journeys
- Consent gates + clear notices; keep audit trails
- Tag governance: approved vendors + page-scope rules
- Prefer aggregated/synthetic analytics when possible

Artifacts that unblock teams

- Data-flow map (“where PHI lives”)
- Model card (intended use + limitations)
- Threat model mapping (OWASP / ATLAS)
- Security/privacy test plan + evidence folder

30 / 60 / 90-day plan

30 days

inventory data flows + AI use cases; MFA everywhere

60 days

logging standards; leakage/prompt tests; vendor reviews

90 days

formal AI risk review; automate checks; run tabletop

Quick checklist (take a photo)

- ☐ Do we know where ePHI is collected, stored, and transmitted?
- ☐ Is MFA + least privilege enforced for every access path?
- ☐ Have we tested for leakage and prompt injection?
- ☐ Can we restore critical workflows if systems go down?
- ☐ Do we have audit-ready evidence of controls?

Closing

- AI security = patient safety + brand trust
- The goal is controlled risk, not perfect risk
- Design for trust → ship faster and sleep better

Q&A

Ask anything — I’ll answer in plain English